Command-and-Control im Red Teaming: Technische Analyse aktueller Frameworks und Implikationen für Obfuscation

Projektarbeit
im Studiengang Angewandte Informatik
an der Dualen Hochschule Baden-Württemberg Mannheim

von
Gabriel Ralf Ricarte Lanz

Abgabedatum: 27.08.2026

Bearbeitungszeitraum	08.01.2026-27.08.2026
Matrikelnummer, Kurs	6613445, TINF24AI1
Ausbildungsfirma	ABB AG
Betreuer	Tran, Jake
Unterschrift Betreuer	_____

Sperrvermerk

Der Inhalt dieser Arbeit darf weder als Ganzes noch in Auszügen Personen außerhalb des Prüfungsprozesses und des Evaluationsverfahrens zugänglich gemacht werden, sofern keine anders lautende Genehmigung des Dualen Partners vorliegt.

Erklärung

Ich versichere hiermit, dass ich meine Bachelorarbeit (bzw. Projektarbeit oder Studienarbeit bzw. Hausarbeit) mit den Themen: Automatisierte Analyse und Vergleich von Gruppenrichtlinienobjekten & Evaluierung von Verschleierungstechniken für Penetrationstests selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Ich versichere zudem, dass die eingereichte elektronische Fassung mit der gedruckten Fassung übereinstimmt.

Frankfurt am Main, den 27.08.2026

Ort, Datum	Unterschrift

Abstract

The present report addresses two key areas in the field of IT security and system administration. The first part presents an automated approach for analyzing and comparing Group Policy Objects (GPOs), enabling a systematic comparison between ABB's internal configurations and those of customer environments. The goal is to efficiently identify deviations, security gaps, and opportunities for optimization.
The second part focuses on the evaluation of modern obfuscation techniques used in penetration testing. Various methods are examined in terms of their effectiveness, detectability, and practical applicability. The combination of both topics provides a practical contribution to enhancing IT security in industrial environments.

Inhaltsverzeichnis

Sperrvermerk **i**

Erklärung zur Eigenleistung **ii**

Abstract **iii**

Inhaltsverzeichnis **iv**

Abbildungsverzeichnis **vi**

Tabellenverzeichnis (Eigene Darstellung) **vii**

Abkürzungsverzeichnis **viii**

Überblick der Tätigkeiten der Praxisphasen **ix**

Vorwort **x**

1 Einleitung **1**
1.1 Ziel der Praxisarbeit 1
1.2 Einordnung von Command-and-Control (C2) im Red Teaming . 1
1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen 2

2 Theoretische Grundlagen **3**
2.1 Command-and-Control (C2) - Grundkonzept 3
2.1.1 Definition und Zweck von C2 3
2.1.2 Klassischer Kill-Chain Kontext 3
2.1.3 Beaconing und Kommunikation in C2-Frameworks 3
2.2 Anforderungen an moderne C2-Frameworks 3
2.2.1 Stealth und OPSEC 3
2.2.2 Modularität 3
2.2.3 Umgehung von EDR/AV-Systemen 3
2.2.4 Flexibilität und Anpassungsfähigkeit 3

3 Überblick über gängige C2-Frameworks **4**
3.1 Metasploit (MSF) 4
3.2 Cobalt Strike 4
3.3 Sliver 4
3.4 Weitere C2-Frameworks 4
3.4.1 Empire 4
3.4.2 Pupy 4
3.4.3 Koadic 4

4 Sliver - Detaillierte Analyse **5**
4.1 Architektur 5
4.2 Funktionalitäten 5
4.2.1 Kommunikationsprotokolle 5
4.2.2 Payloads 5
4.2.3 Post-Exploitation 5
4.3 Stealth und OPSEC 5

5 Vergleichende Gegenüberstellung der C2-Frameworks **6**
5.1 Techischer Vergleich 6
5.2 Detection und Blue-Team-Sicht 6
5.3 Einsatzszenarien 6

6 Praxisbezug **7**
6.1 7

7 Obfuscation als logische Weiterentwicklung **8**
7.1 Identifizierte Schwachstellen moderner C2s 8
7.2 Motivation für Obfuscation 8
7.3 Ausblick auf kommende Praxisarbeit 8

8 Fazit **9**

Abbildungsverzeichnis

1 Cyber Kill Chain 1

Tabellenverzeichnis

1 Abkürzungsverzeichnis viii
2 Übersicht der Tätigkeiten während der Praxisphasen ix

Abkürzungsverzeichnis

Abkürzung	Bedeutung
ABB	Asea Brown Boveri
AD	Active Directory
ADMX	Administrative Template XML
GPO	Gruppenrichtlinienobjekte
BASF	Badische Anilin- und Sodafabrik
GPMC	Group Policy Management Console
HTML	Hypertext Markup Language
MMC	Microsoft Management Console
VBA	Visual Basic for Applications
XML	Extensible Markup Language
PAEN	Process Automation Energy Industries
SZC	Service Zentralbereich Cyber-Security
IT	Informations Technologie

Tabelle 1: Abkürzungsverzeichnis

Überblick der Tätigkeiten der Praxisphasen

Nr.	Tätigkeit	Zeitraum	Praxisphase
1	Workshop der SZC Abteilung am Standort Frankfurt Praunheim	26.01.26-30.01.26	3
2	Themenbearbeitung: Social Engineering als Service Leistung	26.01.26-30.01.26	3
3	Themenbearbeitung: Command and Control Frameworks im Kontext von Penetration Tests	30.01.26 - 17.03.26	3

Tabelle 2: Übersicht der Tätigkeiten während der Praxisphasen

Vorwort

Die in dieser Arbeit beschriebenen Tätigkeiten wurden im Rahmen der dritten Praxisphase des Studiums bei der **ASEA Brown Boveri AG (ABB)** durchgeführt. Der Praxiszeitraum erstreckte sich über die vereinbarte Dauer der dritten Praxisphase. Die Tätigkeiten fanden an den Standorten Frankfurt am Main und Mannheim statt und wurden in der Abteilung **Process Automation Energy Industries (PAEN)**, konkret im **Service Zentralbereich Cyber-Security (SZC)**, unter der fachlichen Anleitung der betrieblichen Betreuer Philip Dosch und Jake Tran durchgeführt.

Gegenstand dieser Praxisarbeit ist die Analyse moderner **Command-and-Control-Infrastrukturen (C2)** im Kontext von Red-Team-Operationen. Der Schwerpunkt liegt auf der technischen Betrachtung aktueller C2-Frameworks, wobei insbesondere das Framework **Sliver** detailliert analysiert wird. Ergänzend erfolgt eine vergleichende Einordnung weiterer verbreiteter Lösungen, darunter unter anderem **Metasploit** und **Cobalt Strike**, um Gemeinsamkeiten, Unterschiede sowie jeweilige Einsatzszenarien herauszuarbeiten.

Im Rahmen der Arbeit werden zentrale Aspekte moderner C2-Frameworks untersucht, darunter Architekturkonzepte, Kommunikationsmechanismen, Payload-Generierung sowie operative Gesichtspunkte im Hinblick auf Stealth und OPSEC. Ziel ist es, ein fundiertes Verständnis für die Funktionsweise und den praktischen Einsatz dieser Infrastrukturen in realistischen Red-Team-Szenarien zu vermitteln.

Die Analyse zeigt zugleich, dass trotz fortschreitender Entwicklung moderner C2-Frameworks weiterhin erkennbare Schwachstellen in Bezug auf Erkennbarkeit, Signaturbildung und Verhaltensanalyse bestehen. Diese Erkenntnisse verdeutlichen die Notwendigkeit zusätzlicher Maßnahmen zur Tarnung von Payloads und Kommunikationsmustern, insbesondere im Umfeld zunehmend leistungsfähiger Endpoint-Detection-and-Response-Systeme.

Aufbauend auf den Ergebnissen dieser Praxisphase ergibt sich eine inhaltliche Überleitung zur vierten Praxisphase, in der der Fokus auf der vertieften Auseinandersetzung mit **Obfuscation-Techniken** liegen wird. Geplant ist dabei die Konzeption und Entwicklung einer eigenen **Obfuscation-Toolbox**, welche gezielt auf die im Rahmen dieser Arbeit identifizierten Schwachstellen moderner C2-Infrastrukturen eingeht und deren Einsatz in Red-Team-Operationen weiter optimiert.

Abschließend möchte ich mich bei meinen Praxisbetreuern, meinem Vorgesetzten sowie bei allen Kolleginnen und Kollegen der Abteilung bedanken, die mich während der dritten Praxisphase fachlich unterstützt haben und jederzeit für einen offenen Austausch zur Verfügung standen.

1 Einleitung

1.1 Ziel der Praxisarbeit

Gegenstand dieser Praxisarbeit ist die technische Analyse moderner Command-and-Control-Frameworks (C2) im Kontext von Red-Team-Operationen. Im Fokus stehen dabei Architekturkonzepte, Kommunikationsmechanismen sowie operative Eigenschaften aktueller C2-Lösungen. Exemplarisch wird das Framework Sliver detailliert untersucht und mit weiteren etablierten Frameworks wie Metasploit und Cobalt Strike vergleichend eingeordnet.

Auf Basis dieser Analyse werden die Einsatzmöglichkeiten moderner C2-Frameworks im Rahmen realitätsnaher Angriffssimulationen bewertet. Dabei werden sowohl technische Kriterien als auch operationelle Gesichtspunkte wie Skalierbarkeit, Flexibilität und Stealth betrachtet. Die gewonnenen Erkenntnisse dienen als Grundlage für die Einordnung des praktischen Nutzens von C2-Infrastrukturen in professionellen Sicherheitsprüfungen und im Kontext angebotener Penetrationstests.

1.2 Einordnung von Command-and-Control (C2) im Red Teaming

Im Red Teaming stellt Command-and-Control eine zentrale Phase innerhalb der Cyber Kill Chain[1] dar. Nach erfolgreicher Kompromittierung eines Zielsystems ermöglicht eine C2-Infrastruktur die fortlaufende Steuerung kompromittierter Systeme, die Durchführung weiterer Aktionen sowie die Koordination komplexer Angriffsszenarien. Ohne eine funktionierende C2-Kommunikation ist eine nachhaltige und realitätsnahe Simulation moderner Angreifer nicht möglich.

Abbildung 1: Cyber Kill Chain

Im Gegensatz zu klassischen Penetrationstests, die häufig auf die Identifikation einzelner Schwachstellen fokussiert sind, zielt Red Teaming auf die Nachbildung vollständiger Angriffsabläufe ab. C2-Frameworks übernehmen hierbei die Rolle der zentralen Steuerungsinstanz und bilden die technische Grundlage für Post-Exploitation-Aktivitäten, laterale Bewegungen und persistente Zugriffsmechanismen. Ihre Ausgestaltung beeinflusst maßgeblich die Realitätsnähe und Aussagekraft einer Red-Team-Operation.

1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen

Moderne IT-Infrastrukturen sind zunehmend durch fortschrittliche Sicherheitsmechanismen wie Endpoint Detection and Response (EDR), Netzwerküberwachung und verhaltensbasierte Erkennungsverfahren geschützt. Vor diesem Hintergrund gewinnen leistungsfähige und flexibel einsetzbare C2-Frameworks eine besondere Bedeutung, da sie es ermöglichen, das Verhalten realer Angreifer realitätsnah abzubilden und bestehende Sicherheitsmaßnahmen gezielt zu evaluieren.

Für die Abteilung Service Zentralbereich Cyber-Security (SZC) der ABB ergibt sich daraus ein direkter Mehrwert, da im Rahmen der angebotenen Sicherheitsdienstleistungen, insbesondere bei Penetrationstests, eine realistische Angreifersimulation zunehmend an Bedeutung gewinnt. Der Einsatz moderner C2-Frameworks erlaubt es, über rein punktuelle Schwachstellenanalysen hinauszugehen und die Widerstandsfähigkeit von Systemen und Prozessen gegenüber fortgeschrittenen Angriffsszenarien zu bewerten.

Die in dieser Praxisarbeit untersuchten C2-Frameworks tragen somit dazu bei, die Qualität und Aussagekraft von Penetrationstests als Serviceleistung zu erhöhen und bilden zugleich eine technische Grundlage für weiterführende Fragestellungen, beispielsweise im Bereich der Tarnung von Payloads und Kommunikationsmustern. Diese Aspekte stellen eine sinnvolle Überleitung zu vertiefenden Untersuchungen in nachfolgenden Praxisphasen dar.

2 Theoretische Grundlagen

2.1 Command-and-Control (C2) - Grundkonzept

2.1.1 Definition und Zweck von C2

2.1.2 Klassischer Kill-Chain Kontext

2.1.3 Beaconing und Kommunikation in C2-Frameworks

2.2 Anforderungen an moderne C2-Frameworks

2.2.1 Stealth und OPSEC

2.2.2 Modularität

2.2.3 Umgehung von EDR/AV-Systemen

2.2.4 Flexibilität und Anpassungsfähigkeit

3 Überblick über gängige C2-Frameworks

3.1 Metasploit (MSF)

3.2 Cobalt Strike

3.3 Sliver

3.4 Weitere C2-Frameworks

3.4.1 Empire

3.4.2 Pupy

3.4.3 Koadic

4 Sliver - Detaillierte Analyse

4.1 Architektur

- Server client modell - modulare Struktur - plattformübergreifend (Windows, Linux, macOS)

4.2 Funktionalitäten

4.2.1 Kommunikationsprotokolle

- (HTTP, HTTPS, DNS, etc.)

4.2.2 Payloads

- Staged vs. Stageless -Cross Compilation - Verschiedene Shell-Typen (Reverse Shell, Bind Shell, etc.)

4.2.3 Post-Exploitation

- Privilige Escalation - Enumeration - Persistence - Lateral Movement - Pivoting - Data Exfiltration

4.3 Stealth und OPSEC

- Verschleierungstechniken - Anti-Forensic Features - Erkennung von EDR/AV-Systemen - Vergleich zu cobalt strike

5 Vergleichende Gegenüberstellung der C2-Frameworks

In diesem Kapitel werden die zuvor vorgestellten C2-Frameworks anhand verschiedener Kriterien miteinander verglichen. Ziel ist es, die Stärken und Schwächen der einzelnen Tools herauszuarbeiten und eine fundierte Bewertung ihrer Eignung für unterschiedliche Anwendungsfälle im Red Teaming zu ermöglichen. Die Vergleichskriterien umfassen unter anderem die Benutzerfreundlichkeit, die Flexibilität bei der Anpassung von Payloads, die Fähigkeit zur Umgehung von Sicherheitslösungen sowie die unterstützten Betriebssysteme und Protokolle. Durch diese vergleichende Analyse soll ein umfassender Überblick über die Leistungsfähigkeit der verschiedenen C2-Frameworks gegeben werden, um eine informierte Entscheidung bei der Auswahl des geeigneten Tools für spezifische Angriffsszenarien zu erleichtern.

5.1 Techischer Vergleich

- Kommunikationsprotokolle - Payload-Generierung - Modularität - Erweiterbarkeit

5.2 Detection und Blue-Team-Sicht

- Signaturen - Verhaltensbasierte Erkennung - Netzwerkverkehrsanalyse

5.3 Einsatzszenarien

- Wann Sliver sinnvoller ist - Wann msf ausreicht - warum cobalt strike in manchen Fällen die bessere Wahl sein könnte

6 Praxisbezug

6.1

7 Obfuscation als logische Weiterentwicklung

7.1 Identifizierte Schwachstellen moderner C2s

7.2 Motivation für Obfuscation

7.3 Ausblick auf kommende Praxisarbeit

8 Fazit

Literatur

[1] „Was ist Cyber Kill Chain? — Microsoft Security“, besucht am 18. Feb. 2026. Adresse: https://www.microsoft.com/de-de/security/business/security-101/what-is-cyber-kill-chain.